CIA Part 1 – Final 100 Hard Questions

Foundations, Ethics, Governance/Risk/Control, Fraud (with IT and AI audit focus)

Study Deck

October 17, 2026

Format and blueprint

100 questions, one per slide; the explanation follows each question (why correct, why the others are wrong).

Aligned to the four-domain Part 1 structure: Foundations (35), Ethics and Professionalism (20), Governance, Risk Management and Control (30), Fraud Risks (15).

Terminology follows the Global Internal Audit Standards (board, CAE, advisory services, Three Lines Model).

About 17 items are technical: ITGC, SOC reports, cloud, resilience, cybersecurity, data analytics, AI governance.

All 100 are new and do not repeat the first final set or your original files.

Question: Quality control staff embedded in a production plant, reporting to the plant manager, perform daily checks of finished goods. In the Three Lines Model this activity is:

A. First line.

B. Second line.

C. Third line.

D. Part of the governing body's responsibilities.

Q1 – Explanation

Correct: A. Activities integral to delivering products and managing operational risk under line management belong to the first line.

B wrong: The second line provides risk and compliance expertise and oversight separate from operations.

C wrong: The third line is independent internal audit.

D wrong: The governing body provides oversight, not daily operational checks.

Question: Which is MOST consistent with an agile approach to internal auditing under the Standards?

A. Short iterations with frequent stakeholder communication, while still meeting requirements for supervision, evidence, and documentation.

B. Dropping documentation to save time.

C. Eliminating supervisory review for small engagements.

D. Skipping risk assessment because iterations are short.

Q2 – Explanation

Correct: A. Agile methods can change the delivery approach but not the requirements for quality work.

B wrong: Documentation requirements still apply.

C wrong: Supervision remains required.

D wrong: Risk assessment remains the basis for planning.

Question: The board directs the CAE to remove a high-risk area from the plan to save cost. What should the CAE do?

A. Cover the area anyway without telling the board.

B. Explain the risk of not covering the area and ensure the board's decision and the accepted risk are documented.

C. Remove the area without comment.

D. Resign immediately.

Q3 – Explanation

Correct: B. The CAE informs the board of the consequences; the board's decision and the resulting risk acceptance are recorded.

A wrong: Acting against the board's decision undermines governance.

C wrong: Silence leaves the board unaware of the exposure.

D wrong: Resignation is premature.

Question: Which engagement is an example of an ASSURANCE service?

A. Evaluating the effectiveness of controls over third-party onboarding and giving the board a conclusion.
B. Facilitating a workshop in which managers identify risks in their own units.
C. Coaching a project team on control concepts at its request.
D. Providing observations on a draft policy at management's request, without a conclusion.

Q4 – Explanation

Correct: A. Assurance involves an independent evaluation producing a conclusion for a party other than the process owner.

B wrong: Facilitation is advisory.

C wrong: Coaching is advisory.

D wrong: Observations on a draft policy without a conclusion are advisory.

Question: Management disagrees with the CAE's risk ranking of an area in the internal audit plan. What is the MOST appropriate action?

A. Remove the area from the plan.

B. Rank it as management prefers.

C. Ask the external auditor to arbitrate.

D. Discuss with management; if unresolved, the CAE retains responsibility and presents the risk-based plan to the board.

Q5 – Explanation

Correct: D. The plan is the CAE's responsibility, informed by management input and approved by the board.

A wrong: That lets management control the plan.

B wrong: That abandons the CAE's risk assessment.

C wrong: The external auditor has no authority over the plan.

Set 2

Question: Who is responsible for developing, implementing, and maintaining the quality assurance and improvement program?

A. The chair of the audit committee.

B. The external assessor.

C. The CAE, with oversight by the board.

D. Each auditor independently, with no coordination.

Q6 – Explanation

Correct: C. The CAE owns the program and reports on it, and the board oversees it.

A wrong: The board oversees but does not run the program.

B wrong: The external assessor evaluates at least every five years but does not own the program.

D wrong: A program requires coordinated management.

Set 2

Question: Management asks internal audit to review the organization's sustainability reporting. What is the MOST appropriate scope?

A. Give an opinion on the scientific validity of climate targets.

B. Evaluate governance, risk management, and controls over the collection and reporting of sustainability data.

C. Prepare the sustainability disclosures.

D. Set the organization's emissions targets.

Q7 – Explanation

Correct: B. Internal audit assesses processes and controls over reported information without taking management responsibilities.

A wrong: That requires scientific expertise beyond the question of process and control.

C wrong: Preparing disclosures is a management responsibility.

D wrong: Setting targets is a management decision.

Question: Compared with a cyclical audit plan, a risk-based plan:

A. Audits every area at the same interval.

B. Is set according to management's preferences.

C. Prioritizes coverage by assessed risk, so higher-risk areas may be audited more often.

D. Excludes advisory services.

Q8 – Explanation

Correct: C. Risk-based planning allocates resources by risk rather than rotation.

A wrong: That describes a simple cyclical plan.

B wrong: Management preference is not a risk assessment.

D wrong: Advisory services may be included.

Question: When may a report state that work was conducted in conformance with the Standards?

A. Whenever the CAE believes the work was good.

B. Only when the results of the quality program support the statement.

C. Always, since the Standards are mandatory.

D. If the external auditor agrees.

Q9 – Explanation

Correct: B. A conformance claim must be supportable by the results of the quality assurance and improvement program.

A wrong: Belief alone is not support.

C wrong: Being mandatory does not mean conformance is assured.

D wrong: The external auditor does not assess internal audit conformance.

Question: A review of control design for a proposed system, performed while the system is still being designed, is BEST classified as:

A. An advisory service.

B. An assurance engagement on operating effectiveness.

C. A compliance audit.

D. A financial statement audit.

Q10 – Explanation

Correct: A. Pre-implementation design input is advice to the project, with management keeping decision responsibility.

B wrong: Operating effectiveness cannot be assessed before the system operates.

C wrong: No compliance requirement is being assessed.

D wrong: No financial statements are being audited.

Set 2

Question: A multinational has regional internal audit teams. Which approach BEST supports consistent quality?

A. Each region sets its own methodology.

B. Regional CFOs supervise the local teams.

C. Quality is assessed only at group level every five years.

D. The group CAE sets common methodology and supervises and reviews work across regions.

Q11 – Explanation

Correct: D. Consistent methodology and supervision are CAE responsibilities across the function.

A wrong: Divergent methodologies create inconsistent quality.

B wrong: CFO supervision would impair independence.

C wrong: Periodic assessment alone is not ongoing quality management.

Set 2

Question: A new internal audit function is being established. What should the CAE do FIRST?

A. Draft a charter defining mandate and reporting lines and obtain board approval.

B. Hire staff without defining the mandate.

C. Prepare detailed engagement programs.

D. Obtain the external auditor's approval of the audit universe.

Q12 – Explanation

Correct: A. The charter establishes authority, role, and reporting relationships on which the rest depends.

B wrong: Without a mandate, resourcing lacks direction.

C wrong: Engagement programs depend on a plan and mandate.

D wrong: The external auditor has no approval role.

Set 2

Question: Which statement BEST reflects the mission of internal audit under the Global Internal Audit Standards?

A. Help management meet its targets by taking responsibility for risk decisions and control design.

B. Provide the external auditor with the evidence needed to support the financial statement opinion.

C. Enhance and protect organizational value by providing risk-based and objective assurance, advice, and insight.

D. Enforce compliance with policies by investigating and disciplining violations.

Q13 – Explanation

Correct: C. The mission is to enhance and protect organizational value through risk-based, objective assurance, advice, and insight.

A wrong: Internal audit must not take management's decision-making responsibilities.

B wrong: Supporting the external audit is not the mission; internal audit serves the board and management.

D wrong: Enforcement and discipline are management responsibilities.

Question: Management asks internal audit to help set the company's new strategic objectives. What is the MOST appropriate role?

A. Define the objectives, since internal audit knows the business best.

B. Approve the objectives before the board reviews them.

C. Refuse any involvement in strategy-related matters.

D. Provide assurance and advice on governance and risk considerations in the strategy-setting process, without setting the objectives.

Q14 – Explanation

Correct: D. Internal audit can provide insight and advice but must not assume management's decision-making role.

A wrong: Setting objectives is a management responsibility.

B wrong: Approval would be a management or governance decision.

C wrong: Advisory involvement is permitted when objectivity is preserved.

Set 2

Question: A department head refuses access to records, citing sensitivity, and the CAE cannot resolve this with him. What should the CAE do?

A. Close the engagement without comment.

B. Substitute interview evidence and not mention the restriction.

C. Ask the external auditor to obtain the records.

D. Escalate to senior management and, if still unresolved, to the board, because it is a restriction on access.

Q15 – Explanation

Correct: D. Restrictions on access affect the mandate and must be escalated until resolved or the board is informed.

A wrong: Closing silently hides a limitation.

B wrong: Not disclosing the limitation misleads readers of the results.

C wrong: The external auditor cannot obtain the records on internal audit's behalf.

Question: How should the CAE plan for emerging risks that arise between planning cycles?

A. Fix the plan for the year to protect independence.

B. Rely on the external auditors to identify emerging risks.

C. Add emerging risks only at the next annual cycle.

D. Include flexible capacity and reassess risks periodically so the plan can be adjusted.

Q16 – Explanation

Correct: D. A risk-based plan must stay current, with capacity to respond to change.

A wrong: A rigid plan may miss significant risks.

B wrong: External auditors have a different focus.

C wrong: Waiting for the next cycle leaves new risks uncovered.

Question: Which authority must the internal audit mandate provide so the function can carry out its work?

A. Authority to direct employees to change their processes.

B. Unrestricted access to the records, personnel, and physical properties relevant to engagements.

C. Authority to approve management's budgets.

D. Authority to approve risk responses.

Q17 – Explanation

Correct: B. Access to information, people, and property is essential for independent evaluation.

A wrong: Directing process changes is a management role.

C wrong: Approving budgets is a management role.

D wrong: Approving risk responses is a management responsibility.

Set 2

Question: What is the main benefit of including root-cause analysis in findings?

A. It identifies the underlying reason for the condition so recommendations address the cause, not symptoms.

B. It assigns blame to individuals.

C. It reduces the need for criteria.

D. It guarantees that management agrees.

Q18 – Explanation

Correct: A. Understanding the cause helps produce more effective, lasting solutions.

B wrong: Root-cause analysis focuses on process and system causes, not blame.

C wrong: Criteria remain necessary.

D wrong: Agreement is not guaranteed.

Question: The CAE proposes shifting the function from mostly compliance work to more advisory and strategic support. What is required?

A. Obtain the CEO's verbal agreement.

B. Update the charter and plan to reflect the change, with board approval and a review of resources and competencies.

C. No action, since the Standards cover both types.

D. Obtain the external auditor's consent.

Q19 – Explanation

Correct: B. A change in mandate or focus affects the charter, plan, and resources, which the board approves.

A wrong: A verbal agreement from the CEO does not change the mandate.

C wrong: The mandate and plan still need to be updated.

D wrong: The external auditor has no role.

Question: A report omits information that readers need to understand its conclusions. Which communication quality is MOST lacking?

A. Completeness.

B. Conciseness.

C. Timeliness.

D. Objectivity.

Q20 – Explanation

Correct: A. Complete communications include all relevant information needed by the intended users.

B wrong: Conciseness means avoiding unnecessary detail, not omitting necessary information.

C wrong: Timeliness concerns when the report is delivered.

D wrong: Objectivity concerns fairness and lack of bias.

Set 2

Question: Which information should the CAE report to the board periodically?

A. Only the list of findings closed.

B. Only issues that management agrees are significant.

C. Performance against the plan, conformance with the Standards, significant risk and control issues, and action plan status.

D. Only budget utilization.

Q21 – Explanation

Correct: C. The board needs a complete view of the function's performance, quality, and significant matters.

A wrong: That is too narrow.

B wrong: Management agreement should not filter board reporting.

D wrong: Budget alone does not support oversight.

Question: Which statement BEST distinguishes internal audit from external audit?

A. Internal audit expresses the opinion on financial statements for shareholders.

B. Internal audit serves the board and management with a broad focus on governance, risk, and control; external audit primarily supports an opinion on financial statements for external users.

C. External audit reports to the CAE.

D. They have identical scope, differing only in staff.

Q22 – Explanation

Correct: B. The two functions differ in audience, scope, and objectives, though they coordinate.

A wrong: External auditors express the financial statement opinion.

C wrong: External auditors do not report to the CAE.

D wrong: Their scope and purpose differ.

Set 2

Question: An auditor leads a workshop in which managers identify and rate risks in their own units, and management keeps ownership of the results. This is BEST classified as:

A. An advisory service (facilitation).

B. An assurance engagement.

C. An investigation.

D. An external audit procedure.

Q23 – Explanation

Correct: A. Facilitation helps management while management retains ownership of the content and decisions.

B wrong: No independent conclusion is provided to a third party.

C wrong: There is no allegation being examined.

D wrong: It is not part of an external audit.

Question: Which statement correctly distinguishes continuous monitoring from continuous auditing?

A. Internal audit performs continuous monitoring and management performs continuous auditing.

B. Management performs continuous monitoring of controls and risks; internal audit performs continuous auditing to independently assess them.

C. Both are performed only by external auditors.

D. Continuous auditing replaces the need for any management monitoring.

Q24 – Explanation

Correct: B. Monitoring is a management responsibility; continuous auditing is the independent assurance counterpart.

A wrong: That reverses the roles.

C wrong: Neither is limited to external auditors.

D wrong: Management remains responsible for monitoring its controls.

Set 2

Question: Which of the following is a responsibility of the board, as opposed to the CAE or management, in relation to internal audit?

A. Designing the audit program for each engagement.

B. Approving the risk-based internal audit plan and the internal audit resource plan.

C. Selecting the sampling method for testing.

D. Deciding the wording of engagement observations.

Q25 – Explanation

Correct: B. The board approves the plan and resource plan, which supports independence and oversight of the function.

A wrong: Engagement programs are designed by internal audit.

C wrong: Testing methods are an engagement-level decision for internal audit.

D wrong: Observation wording is determined by internal audit, not the board.

Set 2

Question: A manager from the sales department joins internal audit for a six-month rotation. Which first assignment is MOST appropriate?

A. An assurance engagement on sales commissions.

B. An assurance engagement on the sales order process.

C. An audit of a function unrelated to sales, with supervision.

D. A review of his former team's controls.

Q26 – Explanation

Correct: C. Objectivity is presumed impaired for assurance on areas the auditor was responsible for within the prior 12 months.

A wrong: He was recently responsible for sales activities.

B wrong: The same presumption applies.

D wrong: That is the area he just left.

Question: Which person would be disqualified from serving on an external quality assessment team?

A. A consultant who designed the function's audit methodology last year.

B. An experienced CIA from another organization with no ties to the function.

C. A professional trained in quality assessment methodology.

D. A CAE from an unrelated company who is competent in the Standards.

Q27 – Explanation

Correct: A. Assessors must be independent and free of conflicts; reviewing one's own design is a self-review conflict.

B wrong: Independent and qualified.

C wrong: Qualified with no conflict indicated.

D wrong: Independent and competent.

Question: A subsidiary's CFO proposes that the local internal audit team report to him. What is the MOST appropriate response from the group CAE?

A. Accept, since the CFO knows the subsidiary best.

B. Disband the local team.

C. Let the subsidiary board decide without group involvement.

D. Maintain functional reporting of the local team to the group CAE and board, with administrative arrangements agreed locally.

Q28 – Explanation

Correct: D. Functional reporting to the CAE and board protects independence; administrative support may be local.

A wrong: Reporting to the CFO would impair independence.

B wrong: Disbanding is unnecessary.

C wrong: The group CAE's role over the function must be maintained.

Set 2

Question: Management has not implemented an agreed action plan for a high-risk finding by the due date. What should the CAE do FIRST?

A. Close the finding because the due date has passed.

B. Report management to the regulator.

C. Understand the reason for the delay and discuss status with management, escalating according to policy if the risk remains unaddressed.

D. Issue a new finding on management's competence.

Q29 – Explanation

Correct: C. Follow-up starts with understanding the cause, then escalation if the risk persists.

A wrong: Closing leaves the risk unresolved.

B wrong: Going to a regulator skips internal escalation channels.

D wrong: That is premature and not evidence-based.

Question: Who is responsible for ensuring that engagement records are retained in line with organizational policy and legal requirements?

A. The records management department of the auditee.

B. The CAE.

C. The external auditor.

D. The audit committee chair.

Q30 – Explanation

Correct: B. The CAE is responsible for the control of engagement records and their retention.

A wrong: The auditee does not control audit records.

C wrong: The external auditor has no role.

D wrong: The board oversees but does not manage records.

Question: Which is a responsibility of senior management regarding internal audit?

A. Deciding the scope and conclusions of each engagement.

B. Supporting the function by ensuring access to people and records and cooperation needed to carry out its mandate.

C. Approving final reports before they go to the board.

D. Evaluating the CAE's performance without board input.

Q31 – Explanation

Correct: B. Senior management supports the function and its mandate; it does not direct engagement scope or conclusions.

A wrong: Management directing scope and conclusions would impair independence.

C wrong: Pre-approval of reports by management would filter board communication.

D wrong: Performance evaluation of the CAE is a board matter, with management input.

Question: Which of the following is NOT a characteristic of the third line in the Three Lines Model?

A. Providing independent and objective assurance.
B. Owning and managing risks as part of day-to-day operations.
C. Reporting to the governing body on its conclusions.
D. Remaining independent from management's responsibilities.

Q32 – Explanation

Correct: B. Owning and managing risks day to day is a first-line responsibility.

A wrong: This is a third-line characteristic.

C wrong: This is a third-line characteristic.

D wrong: This is a third-line characteristic.

Set 2

Question: A regulator asks for copies of internal audit reports. What should the CAE do?

A. Follow the established protocol: consult senior management, legal counsel, and the board as appropriate before release, in line with law and policy.

B. Refuse because reports are confidential.

C. Release all reports immediately.

D. Let the audited units decide what to release.

Q33 – Explanation

Correct: A. Disclosure to outside parties should be controlled and consistent with law and policy.

B wrong: Refusing may violate legal or regulatory requirements.

C wrong: Unreviewed release may exceed what is required.

D wrong: Audited units have a conflict of interest.

Set 2

Question: An engagement was completed with a restriction on information the auditors could obtain. What must the engagement communication include?

A. Nothing, if the auditors believe the remaining evidence is sufficient.

B. The limitation, but only in the workpapers.

C. A statement that the scope was fully achieved.

D. The limitation and its possible effect on the conclusions.

Q34 – Explanation

Correct: D. Transparency about limitations helps users interpret the conclusions.

A wrong: Board and management cannot assess reliance without knowing about the limitation.

B wrong: Workpapers are not read by report users.

C wrong: That would be inaccurate.

Question: Which is the BEST evidence that internal audit adds value for the board?

A. The number of reports issued.

B. Audit budget as a percentage of revenue.

C. Recommendations and insights that improve risk management and control outcomes, supported by board and stakeholder feedback.

D. The number of auditors holding certifications.

Q35 – Explanation

Correct: C. Value is demonstrated by outcomes and stakeholder perception, not by activity or input counts.

A wrong: Output counts do not show impact.

B wrong: Cost ratios say nothing about value delivered.

D wrong: Certifications are an input, not an outcome.

Question: An auditor reports truthfully on a fraud-related finding despite pressure from senior management to stay silent. Which element of the Code of Ethics is MOST directly demonstrated?

A. Competency.

B. Confidentiality.

C. Integrity, including honesty and professional courage.

D. Cost efficiency.

Q36 – Explanation

Correct: C. Integrity includes honesty and the courage to report even under pressure.

A wrong: Competency concerns skills.

B wrong: Confidentiality concerns protection of information.

D wrong: Cost efficiency is not an ethical principle in the Code.

Question: The CAE believes management has committed an illegal act and the board has not acted. What is the MOST appropriate next step?

A. Report immediately to the media.

B. Resign without further action.

C. Do nothing since the board has decided.

D. Consult legal counsel on legal and professional obligations and escalate within the governance structure before considering other action.

Q37 – Explanation

Correct: D. The CAE considers legal and professional obligations and pursues escalation through appropriate channels.

A wrong: Media disclosure breaches confidentiality and is premature.

B wrong: Resignation does not address the matter.

C wrong: Inaction ignores a serious legal concern.

Question: An auditor plans to analyze employee emails with an analytics tool for an engagement. What should happen FIRST?

A. Run the analysis first and seek approval if the results are significant.

B. Share the dataset with the vendor for faster processing.

C. Confirm the legal basis, policies, and approvals for using personal data, and limit use to what the engagement requires.

D. Skip approvals since internal audit has unrestricted access.

Q38 – Explanation

Correct: C. Access rights do not override privacy law and policy; use of personal data must be authorized and proportionate.

A wrong: Approval should come before processing.

B wrong: Sharing data externally increases risk.

D wrong: Unrestricted access to records does not remove legal and policy constraints.

Question: The audit team uses an external IT specialist. Which statement is MOST accurate regarding due professional care?

A. The CAE must evaluate the specialist's competence and objectivity and remains responsible for the conclusions.

B. The specialist's conclusions can be adopted without review.

C. Responsibility transfers to the specialist.

D. Specialists need not be independent.

Q39 – Explanation

Correct: A. Using a specialist does not transfer accountability for internal audit's conclusions.

B wrong: Unreviewed reliance is not due care.

C wrong: Responsibility stays with internal audit.

D wrong: Objectivity of the specialist must be assessed.

Set 2

Question: An auditor had a personal dispute with the manager of the area she is auditing. What is the MOST appropriate action?

A. Continue; being professional is enough.

B. Continue but avoid the manager entirely.

C. Resign from the function.

D. Disclose it to the CAE, who determines whether to reassign or add safeguards.

Q40 – Explanation

Correct: D. Personal bias can impair objectivity and should be disclosed so the CAE can respond.

A wrong: Self-assessment of bias is not sufficient.

B wrong: Avoiding the manager limits the work and doesn't remove bias.

C wrong: Resignation is disproportionate.

Set 2

Question: An auditor posts an anonymized description of an ongoing audit finding on social media. Which statement is MOST accurate?

A. It is acceptable because names were removed.

B. It likely breaches confidentiality, because engagement information should not be disclosed without authority even if the entity is not named.

C. It is acceptable if it contains no financial figures.

D. It is acceptable if posted after working hours.

Q41 – Explanation

Correct: B. Auditors protect information obtained in the course of work; anonymization does not authorize disclosure.

A wrong: Context may still identify the organization.

C wrong: Non-financial details can also be sensitive.

D wrong: Timing does not change the obligation.

Question: Who must conform to the Code of Ethics?

A. Only certified internal auditors.

B. Only the CAE.

C. Only auditors performing assurance.

D. All internal auditors, including the CAE and staff who are not certified.

Q42 – Explanation

Correct: D. The Code applies to all those who provide internal audit services.

A wrong: Conformance is not limited to certified staff.

B wrong: It applies to all staff.

C wrong: It applies to advisory as well.

Set 2

Question: Out of curiosity, an auditor shares draft findings with a manager from another department who has no need to know. Which principle is MOST directly violated?

A. Confidentiality.

B. Competency.

C. Objectivity.

D. Sampling methodology.

Q43 – Explanation

Correct: A. Engagement information must be shared only with authorized parties.

B wrong: Competency concerns skills and knowledge.

C wrong: Objectivity concerns bias and impairments.

D wrong: Sampling is a technique and not a principle.

Set 2

Question: The auditee proposes the audit program and asks that internal audit follow it. What is the MOST appropriate response?

A. Adopt it to maintain a cooperative relationship.

B. Adopt it but reduce the testing.

C. Consider management's input but retain responsibility for scope and procedures based on risk and engagement objectives.

D. Reject all input from management.

Q44 – Explanation

Correct: C. Internal audit determines scope and procedures independently while taking relevant input.

A wrong: Adopting auditee-designed procedures risks independence.

B wrong: Reducing testing weakens the work.

D wrong: Management input can be valuable.

Set 2

Question: The CEO asks the CAE to issue a positive conclusion on a project by Friday, but the audit work will not be finished. What should the CAE do?

A. Issue the conclusion now and finish the work later.

B. Issue it with boilerplate wording only.

C. Not issue an unsupported conclusion; limit the communication to work completed and explain the scope limitation.

D. Ask the auditor to sign without review.

Q45 – Explanation

Correct: C. Conclusions must be supported by sufficient evidence, and limits must be disclosed.

A wrong: That issues an unsupported conclusion.

B wrong: Boilerplate does not address lack of evidence.

D wrong: Review is required.

Question: While auditing inventory, an auditor finds indications of illegal waste dumping that are unrelated to her scope. What should she do?

A. Ignore it, as it is out of scope.

B. Report it promptly to the CAE so it can be communicated to appropriate parties, rather than ignoring it as out of scope.

C. Confront the plant manager.

D. Report only to a regulator.

Q46 – Explanation

Correct: B. Auditors behave legally and ethically and communicate significant matters through the CAE.

A wrong: Ignoring a possible legal violation is inappropriate.

C wrong: Confrontation could compromise any inquiry.

D wrong: Reporting outside the organization first bypasses governance channels.

Set 2

Question: An auditor is invited to join a management steering committee for a new system, with a vote. What is the BEST response?

A. Decline voting membership; she may provide advice or observe while management retains decisions.

B. Accept, since it builds knowledge.

C. Accept but abstain from voting.

D. Accept if membership is rotated annually.

Q47 – Explanation

Correct: A. Participating in management decisions creates a self-review threat and can prevent later assurance.

B wrong: Knowledge gain does not offset the impairment.

C wrong: Membership still integrates her in management's decisions.

D wrong: Rotation does not cure the problem.

Question: Which safeguard BEST addresses a familiarity threat caused by long assignment to the same area?

A. Increasing sample sizes.

B. Using only a standard work program.

C. Rotating assignments or adding independent review of the work.

D. Shortening interview time.

Q48 – Explanation

Correct: C. Rotation and independent review reduce the influence of long relationships.

A wrong: Sample size does not address relationship bias.

B wrong: A standard program does not address relationships.

D wrong: Less interaction time does not fix the threat.

Question: An auditor uses a machine-learning tool to flag anomalies but does not understand its limitations. Which principle is MOST at risk?

A. Confidentiality.

B. Competency.

C. Organizational independence.

D. Privilege against disclosure.

Q49 – Explanation

Correct: B. Competency includes understanding tools and techniques used and their limitations.

A wrong: Confidentiality is not the issue here.

C wrong: Independence concerns reporting lines.

D wrong: Privilege is a legal concept not relevant here.

Question: An auditor learns of a pending acquisition during an engagement and mentions it to her spouse, who buys shares in the target. Which statement is MOST accurate?

A. It is acceptable because the auditor did not trade herself.

B. This violates confidentiality and integrity, because engagement information was used for personal gain.

C. It is acceptable if the amount was small.

D. It is acceptable if the deal is announced later.

Q50 – Explanation

Correct: B. Engagement information must not be used for personal gain or disclosed improperly, directly or through others.

A wrong: Enabling a family member to profit still misuses the information.

C wrong: Size does not remove the violation.

D wrong: Later announcement does not cure the misuse.

Question: In exercising due professional care, which factor is LEAST relevant?

A. The probability of significant errors, fraud, or noncompliance.

B. The seniority of the auditee manager.

C. The complexity and extent of work needed.

D. The cost of assurance relative to its potential benefits.

Q51 – Explanation

Correct: B. Due care weighs risk, complexity, and cost-benefit; the auditee's rank is not a factor in procedures needed.

A wrong: Relevant to the work needed.

C wrong: Relevant to the work needed.

D wrong: Relevant to the work needed.

Question: An auditee manager asks the CAE to remove the auditor leading the engagement after she raised findings. What is the MOST appropriate response?

A. Evaluate any substantiated concerns about conduct objectively, but decline reassignment solely because the auditee dislikes the findings.

B. Reassign her to keep relations good.

C. Discard the findings.

D. Let the manager choose the replacement.

Q52 – Explanation

Correct: A. The auditee should not control audit assignments or outcomes; legitimate conduct concerns are still reviewed.

B wrong: That lets the auditee influence the work.

C wrong: Findings must stand on evidence.

D wrong: The auditee's choice would impair independence.

Question: An auditee offers an auditor a $300 sports ticket a few days before the final report. What should the auditor do?

A. Accept it if it is within the auditee's gift policy.

B. Accept it and disclose it after the report.

C. Accept it and donate it to charity.

D. Decline it and inform the CAE, because it could reasonably be seen as impairing objectivity.

Q53 – Explanation

Correct: D. A gift of this value from an auditee during an engagement creates an appearance of impaired objectivity.

A wrong: The auditee's policy does not govern the auditor's obligations.

B wrong: Late disclosure does not remove the threat.

C wrong: Donating does not change that it was accepted.

Question: An auditor uses the organization's audit methodology and templates in a private consulting engagement. Which statement is MOST accurate?

A. It is acceptable since the auditor developed some of the templates.

B. It is acceptable if clients are not competitors.

C. This misuses information and materials acquired through employment, contrary to confidentiality and integrity.

D. It is acceptable if unpaid.

Q54 – Explanation

Correct: C. Organizational materials are not for personal use without authority.

A wrong: Authorship in the course of employment does not transfer ownership.

B wrong: Client identity does not matter.

D wrong: Payment is not the issue.

Question: The audit committee chair privately asks the CAE to downplay a finding concerning a company owned by the chair's relative. What should the CAE do?

A. Downplay the finding to keep the chair's support.

B. Quietly remove the finding.

C. Report the finding accurately and raise the request with the full board or governing body.

D. Tell only the external auditor.

Q55 – Explanation

Correct: C. Integrity and professional courage require accurate reporting despite pressure, and the request should be escalated.

A wrong: Downplaying distorts the message.

B wrong: Removing a valid finding misleads users.

D wrong: The external auditor does not resolve the internal reporting problem.

Set 2

Question: Which is a DIRECTIVE control?

A. A written policy requiring dual authorization for payments above a set limit.

B. A locked server room.

C. A weekly exception report review.

D. Restoring from backups after an outage.

Q56 – Explanation

Correct: A. Directive controls such as policies and procedures guide behavior toward desired outcomes.

B wrong: That is preventive.

C wrong: That is detective.

D wrong: That is corrective.

Set 2

Question: Which factor MOST affects the effectiveness of a management review control?

A. The seniority of the reviewer alone.

B. The precision of the review, including thresholds and follow-up of exceptions.

C. The length of the review report.

D. Whether the review is documented only by email.

Q57 – Explanation

Correct: B. A review control works if it is precise enough to catch errors and exceptions are followed up.

A wrong: Seniority does not ensure precision.

C wrong: Length does not ensure quality.

D wrong: The medium of documentation does not affect operation.

Set 2

Question: Under COSO's 2013 Internal Control - Integrated Framework, the principle of commitment to integrity and ethical values belongs to which component?

A. Control Environment.

B. Control Activities.

C. Information and Communication.

D. Monitoring Activities.

Q58 – Explanation

Correct: A. The control environment includes commitment to integrity and ethical values, oversight, structure, competence, and accountability.

B wrong: Control activities are the actions that mitigate risks.

C wrong: That component covers information quality and communication.

D wrong: Monitoring evaluates the system of internal control.

Question: Ransomware is detected spreading on a file server. What should be the FIRST priority?

A. Pay the ransom immediately.

B. Restore from backups before isolating systems.

C. Wipe affected servers to remove the malware.

D. Contain the incident by isolating affected systems while preserving evidence.

Q59 – Explanation

Correct: D. Containment limits spread; evidence preservation supports investigation.

A wrong: Payment is not a first step and does not guarantee recovery.

B wrong: Restoring before isolation risks reinfection.

C wrong: Wiping destroys evidence and may not stop spread.

Question: Which situation MOST indicates that risk appetite is not embedded in decision-making?

A. Limits are reviewed annually by the board.

B. Exceptions are escalated and logged.

C. Business units approve exposures beyond approved limits without escalation.

D. Appetite statements are linked to strategic objectives.

Q60 – Explanation

Correct: C. Embedding means decisions are made within limits, with escalation of exceptions.

A wrong: That is a sound practice.

B wrong: That shows escalation works.

D wrong: That supports embedding.

Question: Which statement BEST describes a key risk indicator (KRI)?

A. A metric that gives early warning of increasing risk exposure, such as rising turnover in a critical process.

B. A measure of losses already incurred only.

C. The annual external audit opinion.

D. The list of approved controls.

Q61 – Explanation

Correct: A. KRIs are generally forward-looking metrics that signal changes in risk exposure.

B wrong: That describes a lagging metric.

C wrong: An audit opinion is not an indicator.

D wrong: A control list is not a metric.

Set 2

Question: Which control BEST ensures complete and accurate transfer of transactions between two systems?

A. A quarterly interview with the interface owner.

B. Automated reconciliation of record counts and control totals with exception follow-up.

C. A screenshot of the interface status.

D. An annual review of the interface specification.

Q62 – Explanation

Correct: B. Automated count and total reconciliation detects missing or altered records promptly.

A wrong: Interviews do not test data transfer.

C wrong: A screenshot shows status only.

D wrong: Specification review is infrequent and design-only.

Question: A single loss event is estimated at $200,000 with an annual rate of occurrence of 0.25. A control reduces the rate to 0.05 and costs $30,000 per year. What is the net annual benefit?

A. $10,000.

B. $40,000.

C. $20,000.

D. $70,000.

Q63 – Explanation

Correct: A. Annual loss expectancy falls from $50,000 to $10,000, a $40,000 reduction. Less the $30,000 cost, the net benefit is $10,000.

B wrong: That is the gross reduction before cost.

C wrong: That subtracts the cost from the original expectancy rather than from the reduction.

D wrong: That adds the cost instead of subtracting it.

Set 2

Question: In the COSO ERM framework, which component addresses identifying, assessing, and prioritizing risks and selecting responses?

A. Governance and Culture.

B. Strategy and Objective-Setting.

C. Review and Revision.

D. Performance.

Q64 – Explanation

Correct: D. The Performance component covers risk identification, assessment, prioritization, response, and portfolio view.

A wrong: It covers oversight, culture, and values.

B wrong: It covers strategy and objectives.

C wrong: It covers revising practices over time.

Set 2

Question: Which provides the strongest evidence that a vulnerability is actually exploitable?

A. An automated vulnerability scan.

B. A policy review.

C. An asset inventory.

D. A penetration test.

Q65 – Explanation

Correct: D. Penetration testing attempts exploitation and demonstrates real impact.

A wrong: Scans identify potential weaknesses, not proven exploitability.

B wrong: Policies do not test exploitability.

C wrong: An inventory lists assets only.

Question: Which characteristic MOST determines whether a detective control is effective?

A. The number of exceptions generated.

B. Whether it is documented in a policy.

C. Timely investigation and resolution of the exceptions it identifies.

D. Whether the reviewer is senior.

Q66 – Explanation

Correct: C. A detective control works only if exceptions are followed up and corrected.

A wrong: Volume does not show effectiveness.

B wrong: Documentation alone does not prove operation.

D wrong: Seniority does not ensure follow-up.

Question: Which control BEST maintains segregation of duties in a CI/CD environment?

A. Developers approving their own pull requests.

B. Shared deployment credentials known to the team.

C. Post-deployment review once a quarter.

D. Pipeline-enforced peer review and independent approval before deployment, with developers unable to push directly to production.

Q67 – Explanation

Correct: D. Enforced review and approval gates prevent unauthorized or untested changes.

A wrong: Self-approval removes independence.

B wrong: Shared credentials remove accountability.

C wrong: Infrequent review is too late.

Set 2

Question: Which control is MOST important for emergency (firefighter) privileged access?

A. A shared password kept in a team spreadsheet.

B. Permanent privileged access for the on-call team.

C. Time-limited access with approval, full logging, and independent review after use.

D. Verbal approval with no record.

Q68 – Explanation

Correct: C. Emergency access needs approval, limits, logging, and after-the-fact review.

A wrong: Shared passwords destroy accountability.

B wrong: Permanent privileged access defeats least privilege.

D wrong: No record prevents review.

Question: A critical cloud vendor provides no independent assurance report. What should internal audit recommend?

A. Use contractual audit rights or other assurance, such as questionnaires and independent testing, and assess the risk of reliance.

B. Accept the vendor's marketing statements.

C. Assume risk is transferred to the vendor.

D. Stop all use immediately regardless of impact.

Q69 – Explanation

Correct: A. Outsourcing does not transfer accountability; the organization needs alternative assurance.

B wrong: Marketing is not evidence.

C wrong: Accountability remains with the organization.

D wrong: Immediate termination ignores business impact and may not be necessary.

Question: Which practice BEST supports accountability for AI use across the organization?

A. A policy statement with no register.

B. Allowing each team to adopt tools independently.

C. An inventory of AI systems with named owners, risk classification, and approvals at key lifecycle stages.

D. Reviewing vendor brochures annually.

Q70 – Explanation

Correct: C. An inventory with ownership and lifecycle approvals makes AI use visible and governed.

A wrong: Without a register, use is not visible.

B wrong: Uncoordinated adoption weakens governance.

D wrong: Brochures are not governance.

Question: Under GDPR, how quickly must a controller notify the supervisory authority of a personal data breach, where feasible?

A. Within 24 hours of the breach occurring.

B. Within 30 days of discovery.

C. Without undue delay and, where feasible, within 72 hours of becoming aware.

D. Only if the breach affects more than 10,000 individuals.

Q71 – Explanation

Correct: C. The GDPR sets a 72-hour expectation from awareness, unless the breach is unlikely to result in risk.

A wrong: 24 hours is not the requirement.

B wrong: 30 days is too long.

D wrong: There is no fixed individual-count threshold.

Question: Which statement BEST reflects a zero trust approach?

A. Anything inside the corporate network is trusted.

B. Strong perimeter firewalls remove the need for user authentication.

C. Once authenticated, users keep access until their account is closed.

D. No user or device is trusted by default; access is verified continuously and limited by least privilege.

Q72 – Explanation

Correct: D. Zero trust assumes no implicit trust and verifies each request.

A wrong: That is the perimeter model.

B wrong: Firewalls do not replace authentication.

C wrong: Persistent access contradicts continuous verification.

Question: Which control BEST addresses the risk of AI model drift?

A. Ongoing performance monitoring against baselines with thresholds that trigger review or retraining.

B. Annual user training.

C. One-time validation before go-live.

D. Restricting access to the model's source code.

Q73 – Explanation

Correct: A. Drift develops over time, so continuous monitoring and defined triggers are needed.

B wrong: Training does not detect drift.

C wrong: A one-time check cannot detect later changes.

D wrong: Code access does not address performance changes.

Question: Which provides the greatest assurance that recovery of a critical system will work?

A. Reviewing the continuity plan document.

B. A tabletop discussion of recovery steps.

C. A live failover test of the system at the recovery site.

D. Confirming that staff have read the plan.

Q74 – Explanation

Correct: C. Actual failover testing demonstrates that recovery capabilities work in practice.

A wrong: Document review does not test capability.

B wrong: Tabletop exercises test understanding, not technology.

D wrong: Awareness does not prove recoverability.

Question: For a risk with low likelihood but severe impact, which response is typically MOST appropriate?

A. Accept it with no further action.

B. Avoid it by exiting all operations.

C. Rely on historical frequency to ignore it.

D. Share part of the risk, for example through insurance, and prepare contingency plans.

Q75 – Explanation

Correct: D. Low-frequency, high-severity risks are often addressed by sharing and contingency planning.

A wrong: Unmonitored acceptance ignores severe impact.

B wrong: Exiting operations is disproportionate.

C wrong: Historical frequency can understate rare events.

Set 2

Question: Which is the MOST significant finding in an audit of robotic process automation (RPA)?

A. Bots run under shared privileged credentials with no named owner or logging.

B. Bot documentation uses an old template.

C. Bot schedules are reviewed monthly by owners.

D. Bot IDs are unique and have least-privilege access.

Q76 – Explanation

Correct: A. Shared privileged credentials without ownership or logging create accountability and security gaps.

B wrong: A template issue is minor.

C wrong: Owner review is a good practice.

D wrong: Unique least-privilege IDs are a good control.

Question: Which is an ENTITY-LEVEL control?

A. A three-way match on supplier invoices.

B. An edit check on invoice dates.

C. A daily bank reconciliation for one account.

D. A whistleblower hotline and enforcement of the code of conduct.

Q77 – Explanation

Correct: D. Entity-level controls such as ethics programs operate across the organization.

A wrong: That is a transaction-level control.

B wrong: That is an application control.

C wrong: That is an account-level activity.

Question: Which is the BEST indicator of a healthy risk culture?

A. Zero reported incidents over several years.

B. A detailed risk policy exists.

C. Employees feel safe raising concerns and leaders act on them promptly.

D. Risk reports are issued monthly.

Q78 – Explanation

Correct: C. Healthy culture shows in behavior: open escalation and leadership response.

A wrong: Zero incidents may indicate under-reporting.

B wrong: A policy alone does not show behavior.

D wrong: Reporting frequency does not show culture.

Question: Inherent risk is rated impact 5 and likelihood 4 (score 20). Controls reduce likelihood to 2 and impact is unchanged. What is the residual score?

A. 8.

B. 15.

C. 10.

D. 20.

Q79 – Explanation

Correct: C. Residual score is 5 x 2 = 10.

A wrong: That would need impact of 4.

B wrong: That would reduce likelihood only to 3.

D wrong: That ignores the effect of controls.

Set 2

Question: Which ERM component addresses evaluating alternative strategies and the risk profile they imply?

A. Review and Revision.

B. Strategy and Objective-Setting.

C. Information, Communication, and Reporting.

D. Governance and Culture.

Q80 – Explanation

Correct: B. Strategy and Objective-Setting links risk appetite, alternatives, and business objectives.

A wrong: It addresses changes and improvements over time.

C wrong: It addresses information flow.

D wrong: It addresses oversight and culture.

Question: Which cloud finding is MOST significant?

A. Resource tags are inconsistent.

B. The root (account owner) credentials are used daily without multi-factor authentication.

C. Some test instances are left running.

D. Billing alerts are set above the policy threshold.

Q81 – Explanation

Correct: B. Unprotected, routinely used root credentials expose the entire cloud environment.

A wrong: Tagging is an administrative issue.

C wrong: Idle instances are mainly a cost issue.

D wrong: Alert thresholds are a minor monitoring issue.

Question: Which control BEST protects the integrity of system logs?

A. Storing logs on the same server with administrator write access.

B. Allowing application owners to edit logs for clarity.

C. Deleting logs after seven days to save space.

D. Sending logs to a centralized, write-once repository with restricted access and monitoring.

Q82 – Explanation

Correct: D. Centralized, tamper-resistant storage preserves logs for investigation.

A wrong: Local storage with admin write access can be altered.

B wrong: Editable logs lose evidentiary value.

C wrong: Short retention loses evidence.

Question: Employees say middle managers routinely bypass the code of conduct despite senior leaders' statements. What is the MOST appropriate internal audit response?

A. Disregard it because senior leaders set the tone.

B. Treat it as an HR matter outside internal audit's scope.

C. Assess the cultural risk, report it to senior management and the board, and recommend actions to align behavior with stated values.

D. Issue findings against named managers without further work.

Q83 – Explanation

Correct: C. Culture is part of governance and control environment, and internal audit can assess and report on it.

A wrong: Tone in the middle also shapes behavior.

B wrong: Ethics culture is within internal audit's scope.

D wrong: Findings need evidence and due process.

Question: Who should OWN a specific operational risk?

A. The manager accountable for the objective the risk affects.

B. The head of the risk function.

C. The CAE.

D. The external auditor.

Q84 – Explanation

Correct: A. Risk ownership belongs with those accountable for the related objectives (first line).

B wrong: The risk function advises and monitors.

C wrong: Internal audit provides independent assurance.

D wrong: External auditors have no ownership role.

Question: An enterprise chatbot answers questions using internal documents. Which control BEST reduces the risk of exposing sensitive information to unauthorized users?

A. Telling users not to ask sensitive questions.

B. Enforcing source-system access permissions on retrieval, with data loss prevention and logging.

C. Indexing all documents so answers are complete.

D. Relying on a longer system prompt only.

Q85 – Explanation

Correct: B. Technical access enforcement and monitoring are needed rather than reliance on user behavior or prompts.

A wrong: User instructions are not a control.

C wrong: Indexing everything increases exposure.

D wrong: Prompts alone can be bypassed.

Question: Which technique is MOST commonly used to conceal financial statement fraud by senior management?

A. Period-end top-side journal entries without supporting documentation.

B. Small expense claims.

C. Employee cash theft.

D. Vendor discounts.

Q86 – Explanation

Correct: A. Senior management can post unsupported period-end entries that bypass normal controls.

B wrong: That is a small-scale asset misappropriation.

C wrong: That is an employee asset scheme.

D wrong: Discounts are routine.

Question: Accounts payable receives an urgent email appearing to be from the CEO instructing a change to a vendor's bank details. Which control BEST addresses this risk?

A. Replying to the email to confirm.

B. Call-back verification using an independently sourced phone number, and dual approval of bank detail changes.

C. Increasing email storage capacity.

D. Requiring an annual password change.

Q87 – Explanation

Correct: B. Out-of-band verification and dual approval counter business email compromise.

A wrong: Replying uses the possibly compromised channel.

C wrong: Storage is unrelated.

D wrong: Password changes do not stop impersonation.

Question: Under pressure to meet targets, a sales manager backdates contracts into the current quarter. Which control BEST addresses this risk?

A. Higher bonuses for quarter-end results.

B. A reminder email about ethics.

C. Faster commission calculation.

D. Independent revenue-recognition review with cut-off testing of contract dates against delivery and approval records.

Q88 – Explanation

Correct: D. Independent review and cut-off testing detect improper timing of revenue.

A wrong: That increases incentive.

B wrong: Reminders do not detect backdating.

C wrong: Speed of commissions is unrelated.

Question: Which pattern is the MOST likely sign of overstated inventory?

A. Rising turnover with rising sales.

B. Inventory growing faster than sales, with falling turnover and no obsolescence write-downs.

C. Stable inventory with stable sales.

D. Falling inventory while sales rise.

Q89 – Explanation

Correct: B. Disproportionate growth and falling turnover can signal overstated or obsolete inventory.

A wrong: Consistent with healthy growth.

C wrong: Consistent with stability.

D wrong: Consistent with strong sales.

Set 2

Question: Which is the strongest red flag for a bribery scheme?

A. A competitive tender with documented evaluation.

B. A modest documented training expense.

C. A large success fee paid to an intermediary closely tied to a foreign official, with no documented services.

D. A routine invoice from a long-established, unrelated supplier.

Q90 – Explanation

Correct: C. Payments to connected intermediaries without clear services are classic bribery indicators.

A wrong: Transparent and documented.

B wrong: Normal and documented.

D wrong: Routine and unconnected.

Question: Which analytic is MOST effective for detecting fictitious expense claims?

A. Comparing total expenses with last year's total.

B. Recomputing mileage rates.

C. Verifying approvals only for the largest claims.

D. Detecting duplicate or near-duplicate receipts and claims just under approval thresholds.

Q91 – Explanation

Correct: D. Duplicates and threshold clustering are common signs of fabricated claims.

A wrong: Aggregate comparisons miss individual manipulation.

B wrong: Rates test accuracy, not authenticity.

C wrong: Fraud often hides below thresholds.

Question: In a fraud investigation, when should the suspect typically be interviewed?

A. First, to obtain a quick confession.

B. Before securing records.

C. Only if the board requests it.

D. Near the end, after documents and witness evidence have been gathered.

Q92 – Explanation

Correct: D. Interviewing the suspect last allows the investigator to be well prepared and reduces evidence-loss risk.

A wrong: Early interviews tip off the suspect and weaken the case.

B wrong: Records should be secured first.

C wrong: The timing is an investigative decision, not a board request.

Question: Which is a detective control for cash handling fraud?

A. A lock on the safe.

B. Segregation of cash handling and recording.

C. A dual-signature requirement.

D. Surprise cash counts by an independent person.

Q93 – Explanation

Correct: D. Surprise counts detect discrepancies after they occur.

A wrong: Locks prevent access.

B wrong: Segregation prevents concealment.

C wrong: Dual signatures prevent unauthorized payments.

Question: Which fraud risk should the auditor assume exists in every organization?

A. Theft by customers only.

B. Competitor espionage only.

C. Currency translation risk.

D. Management override of controls.

Q94 – Explanation

Correct: D. Management can override controls in any organization, so it must be considered in every assessment.

A wrong: Not universal and not limited to customers.

B wrong: Not a universal fraud risk.

C wrong: That is a financial risk, not a fraud risk.

Question: Which pattern MOST suggests bid rigging?

A. Many independent bidders with widely varying prices.

B. The same few vendors rotate as lowest bidder and submissions contain identical errors.

C. A single qualified vendor in a niche market, with documented justification.

D. Winning bids that vary with the work requirements.

Q95 – Explanation

Correct: B. Rotation and shared mistakes indicate collusion among bidders.

A wrong: Independent prices suggest competition.

C wrong: A documented sole-source can be legitimate.

D wrong: Variation with requirements is normal.

Question: An employee who reported misconduct through the hotline is demoted shortly afterward. What should internal audit do?

A. Treat it as unrelated to internal audit.

B. Report the potential retaliation to the board or audit committee and recommend an independent review.

C. Ask the manager who demoted the employee to investigate.

D. Disclose the reporter's identity to affected managers.

Q96 – Explanation

Correct: B. Retaliation undermines the reporting culture and should go to the governing body.

A wrong: It affects the ethical culture and controls.

C wrong: That manager has a conflict.

D wrong: Revealing identity compounds the harm.

Set 2

Question: Which control BEST prevents altered or forged company checks from being paid by the bank?

A. Positive pay, where the bank matches presented checks to a list of issued checks.

B. Monthly review of bank statements.

C. A policy forbidding alterations.

D. Annual employee ethics training.

Q97 – Explanation

Correct: A. Positive pay stops unauthorized or altered checks before payment.

B wrong: Review is detective and occurs after payment.

C wrong: A policy alone does not stop clearing.

D wrong: Training does not stop altered checks.

Question: A supposedly large vendor submits invoices with consecutive numbers over several months. What does this MOST likely indicate?

A. Strong vendor controls.

B. A system outage.

C. The vendor may be fictitious or have few real customers.

D. A volume discount.

Q98 – Explanation

Correct: C. Sequential numbering from a purportedly large vendor suggests a shell or sham vendor.

A wrong: Consecutive numbering is not evidence of control strength here.

B wrong: Outages do not explain the pattern.

D wrong: Discounts do not relate to numbering.

Question: A retail clerk fails to ring up a cash sale and keeps the money. Which scheme is this?

A. Lapping.

B. A billing scheme.

C. Expense reimbursement fraud.

D. Skimming.

Q99 – Explanation

Correct: D. Skimming is taking cash before it is recorded.

A wrong: Lapping conceals theft by applying later receipts to earlier accounts.

B wrong: Billing schemes involve false invoices.

C wrong: No expense claim is involved.

Question: Which factor MOST strongly deters employee fraud?

A. A strong perception that misconduct will be detected and result in consequences.

B. A longer code of conduct.

C. A higher salary for all staff.

D. An annual fraud video with no testing.

Q100 – Explanation

Correct: A. Perceived likelihood of detection and consequences is a powerful deterrent.

B wrong: Length does not deter without enforcement.

C wrong: Pay does not remove opportunity or rationalization.

D wrong: Passive awareness has limited effect.

Answer key

1:A 2:A 3:B 4:A 5:D 6:C 7:B 8:C 9:B 10:A 11:D 12:A 13:C 14:D 15:D 16:D
17:B 18:A 19:B 20:A 21:C 22:B 23:A 24:B 25:B

26:C 27:A 28:D 29:C 30:B 31:B 32:B 33:A 34:D 35:C 36:C 37:D 38:C 39:A
40:D 41:B 42:D 43:A 44:C 45:C 46:B 47:A 48:C 49:B 50:B

51:B 52:A 53:D 54:C 55:C 56:A 57:B 58:A 59:D 60:C 61:A 62:B 63:A 64:D
65:D 66:C 67:D 68:C 69:A 70:C 71:C 72:D 73:A 74:C 75:D

76:A 77:D 78:C 79:C 80:B 81:B 82:D 83:C 84:A 85:B 86:A 87:B 88:D 89:B
90:C 91:D 92:D 93:D 94:D 95:B 96:B 97:A 98:C 99:D 100:A